

WormLocker 2.0 Ransomware Advanced Malware Analysis Report

November 26, 2025

CONFIDENTIAL

This document contains sensitive malware analysis data.
Distribution restricted to authorized personnel only.

Abstract

This report presents a comprehensive technical analysis of the WormLocker 2.0 ransomware, a sophisticated multi-component malware toolkit targeting Windows operating systems. The analysis encompasses both static code examination and dynamic behavioral assessment conducted in an isolated laboratory environment. WormLocker 2.0 demonstrates advanced capabilities including system-level privilege escalation, Windows login component replacement, AES file encryption, and persistent boot-level hooks. Attribution analysis reveals operational security failures including embedded debug symbols and hardcoded decryption keys. This report provides detailed indicators of compromise (IOCs), detection signatures, and incident response procedures for defensive operations.

Contents

1	Executive Summary	4
1.1	Overview	4
1.2	Threat Assessment	4
2	Analysis Environment	4
2.1	Laboratory Infrastructure	4
2.2	Safety Protocols	4
2.3	Analysis Toolset	5
3	Static Analysis	5
3.1	Sample Identification	5
3.1.1	Primary Sample Metadata	5
3.2	Critical IOCs - Quick Reference	5
3.3	String Analysis	6
3.3.1	Extraction Methodology	6
3.3.2	Critical String Discoveries	6
3.4	PE Structure Examination	7
3.4.1	PE Header Analysis	7
3.4.2	Compiler and Framework Detection	8
3.5	Packing and Obfuscation Assessment	8
3.5.1	Entropy Analysis	8
3.5.2	Packer Detection Tests	8
3.5.3	UPX Detection:	8
3.5.4	YARA Signature Scanning:	9
3.5.5	.NET Metadata Verification	9
3.5.6	Decompilation:	9
3.5.7	Conclusion	10
3.5.8	Developer Identification via PDB Paths	10
3.5.9	Organizational Branding	11
3.6	Indicators of Compromise (IOCs)	11
3.6.1	File-Based IOCs	11
3.6.2	Registry IOCs	11
3.6.3	User Interface Manifestation (T+0:30)	11
3.6.4	System Restart (T+0:45)	12
3.7	Post-Execution Analysis	12
3.7.1	System State After Reboot	12
3.8	Behavioral Analysis Summary	13
3.8.1	Attack Lifecycle Diagram	13
3.8.2	MITRE ATT&CK Mapping	13
3.9	Decryption Key Testing	14
3.9.1	Test Methodology	14
4	Detection and Prevention Strategies	14
4.1	Preventive Controls	14
4.1.1	Endpoint Protection	14
4.1.2	Backup Strategy	15
4.2	Detection Controls	15
4.2.1	Endpoint Detection & Response (EDR)	15
4.3	Host-Based Indicators for Monitoring	16

4.4	Eradication Phase	16
4.4.1	Malware Removal	16
4.4.2	System Hardening	17
4.5	Post-Incident Activities	18
4.5.1	Root Cause Analysis	18
4.5.2	Lessons Learned	18
4.5.3	Threat Intelligence Sharing	18
5	Conclusion	18
5.1	Key Findings Summary	18
5.2	Attribution Assessment	19
5.3	Risk to Organizations	19
A	Reference Materials	20
A.1	MITRE ATT&CK Framework Mapping	20
A.2	Related Research and Resources	21
A.3	Glossary of Terms	21
B	Legal and Ethical Considerations	22
B.1	Analysis Authorization	22
B.2	Responsible Disclosure	22
B.3	Ethical Guidelines Compliance	22

1 Executive Summary

1.1 Overview

WormLocker 2.0 represents an intermediate-to-advanced ransomware threat that extends beyond conventional file encryption to implement system-level sabotage. The malware operates as a coordinated multi-component attack suite comprising six distinct executables that work in concert to encrypt user files, replace critical Windows system components, and establish persistent control over compromised systems.

1.2 Threat Assessment

Attribute	Assessment
Threat Level	HIGH
Sophistication	Intermediate to Advanced
Target	Individual users, European markets
Impact	Complete system compromise
Decryption	Potentially possible (keys discovered)
OPSEC	Poor (traceable infrastructure)
Active Campaign	Historical (2020 development)

Table 1: Threat Assessment Summary

2 Analysis Environment

2.1 Laboratory Infrastructure

All analysis was conducted in a fully isolated virtual environment with no external network connectivity to prevent accidental malware propagation.

VM Name	OS	Purpose
Analysis-VM	Kali Linux 2024.2	Static analysis tools
Victim-VM	Windows 10	Controlled malware execution
Monitor-VM	Kali Linux 2024.2	Network traffic capture

Table 2: Virtual Machine Configuration

2.2 Safety Protocols

- Network isolation via host-only adapter (no internet access)
- Pre-execution VM snapshots for rollback capability
- Disabled shared folders and clipboard sharing
- Windows Defender disabled for behavioral observation
- Academic institution approval obtained prior to analysis

2.3 Analysis Toolset

Tool	Version	Purpose
Detect It Easy (DIE)	v3.10	PE structure, entropy, compiler detection
strings	GNU binutils	ASCII/Unicode string extraction
FLOSS	3.1.1	Advanced .NET string analysis
pescan	pev toolkit	PE header validation
upx	4.2.4	Packer detection
Wireshark	4.2.0	Network traffic analysis

Table 3: Analysis Tool Suite

3 Static Analysis

3.1 Sample Identification

3.1.1 Primary Sample Metadata

Attribute	Value
Filename	Automatic _c onverter _r ff _t omp4.exe
File Type	PE32 executable
File Size	322.50 KB (330240 bytes)
Architecture	x86 (32-bit)
Subsystem	Windows GUI
Framework	.NET Framework 4.0
MD5	1b4f89bdb12a349de92ca7f1261e67a0
SHA1	f368916850332757d7ed2f0ee335c16b9c9fc95b
SHA256	d4c83205cf6f3098ab6a757312525f4d14a57a819306eeea5c0d022b00b38cf3
First Seen	2020-12-16 13:39:19 UTC
Analysis Date	November 26, 2025
Analyst	Mostefaoui Manel

Table 4: Sample Identification Data

3.2 Critical IOCs - Quick Reference

Indicator Type	Value
SHA256 Hash	d4c83205cf6f3098ab6a757312525f4d14a5...
Email Contact	wormlocker789@gmail.com
Fake Login File	C:\Windows\System32\LogonUIinf.exe
Registry Key	HKLM\...\Policies\System\DisableTaskMgr
Found decryption Key 1	LUC QPV BTR
Found decryption Key 2	ff0953qpn7361bbu

Table 5: Critical Indicators of Compromise

3.3 String Analysis

3.3.1 Extraction Methodology

String extraction was performed using multiple encoding methods:

```

1 # ASCII strings (8+ characters)
2 $ strings -n 8 Automatic_converter_rff_to_mp4.exe > strings_ascii.txt
3
4 # Unicode/little-endian strings
5 $ strings -n 8 -el Automatic_converter_rff_to_mp4.exe > strings_unicode.txt
6
7 # Advanced .NET analysis
8 $ floss Automatic_converter_rff_to_mp4.exe > floss_output.txt

```

Listing 1: String Extraction Commands

3.3.2 Critical String Discoveries

Privilege Escalation Command The most dangerous finding - system-level privilege escalation:

```

1 cmd.exe /k takeown /f C:\Windows\System32 && icacls C:\Windows\System32 /grant
  "%username%:F"

```

This command chain:

1. Takes ownership of System32 directory (normally owned by SYSTEM account)
2. Grants Full Control permissions to current user
3. Enables replacement of critical Windows components including LogonUI.exe

System Component Replacement Malicious files deployed to system directories:

```

1 C:\Windows\System32\LogonUIinf.exe      (Fake login - primary)
2 C:\Windows\System32\LogonUItrue.exe    (Fake login - backup)
3 C:\Windows\System32\ransom_voice.vbs   (Audio ransom)

```

Registry modification target:

```

1 SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon

```

```

1 SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System
2 DisableTaskMgr (set to 1)
3
4 shutdown /r /t 0 (forced immediate restart)

```

```

1 Email:    wormlocker789@gmail.com
2 Method:   paysafecard
3 Amount:   50 euros

```

Ransom message excerpt:

"If you do not pay by a certain time or turn off the computer, all your data will be permanently deleted and your computer will not turn on properly."

Cryptographic Implementation .NET cryptography functions identified:

```

1 RijndaelManaged      (AES encryption class)
2 EncryptFile           (Encryption routine)
3 DecryptFile           (Decryption routine)
4 CryptEncrypt           (Windows Crypto API)
5 CryptGenKey            (Key generation)

```

File marking:

```

1
2 Marker:      desktop.ini (modified in encrypted directories)

```

Hardcoded Decryption Keys - Critical Discovery Possible master decryption keys found in plaintext:

```

1 Key Candidate 1: LUC QPV BTR
2 Key Candidate 2: ff0953qpn7361bbu
3 Key Format:      000-000-000

```

Validation strings:

```

1 "Incorrect key" -> "WRONG KEY"
2 "The key is correct" -> "UNLOCKED"

```

Significance: These hardcoded strings suggest poor key management practices and may enable decryption without ransom payment. Requires validation in controlled environment.

3.4 PE Structure Examination

3.4.1 PE Header Analysis

Analysis using pescan revealed the following PE structure characteristics:

```

1 $ pescan WormLocker.exe
2
3 file entropy:              7.330030 (probably packed)
4 fpu anti-disassembly:     no
5 imagebase:                 normal
6 entryptpoint:             normal
7 DOS stub:                  normal
8 TLS directory:            not found
9 timestamp:                 future time
10 section count:            3
11
12 sections
13   .text:                   normal
14   .rsrc:                   normal
15   .reloc:                  small length

```

Listing 2: pescan Output

Key Observations:

- **Elevated Entropy (7.33):** While pescan flags this as "probably packed," further analysis confirms this is due to compressed multimedia resources (lock screen images, audio files) rather than code packing
- **Future Timestamp:** Compilation timestamp shows future date, indicating either deliberate anti-forensics or system clock misconfiguration
- **Standard .NET Structure:** Three-section layout (.text, .rsrc, .reloc) is typical for .NET assemblies

3.4.2 Compiler and Framework Detection

Attribute	Value
Compiler	Microsoft Visual C# / .NET
Framework	.NET Framework 4.0
Linker	Microsoft Linker
Subsystem	Windows GUI (2)
Entry Point	0x00430402
Architecture	x86 (32-bit)

Table 6: Compiler Identification Results

Significance of .NET Implementation:

The use of .NET Framework has critical implications:

- Easier reverse engineering via decompilation tools (dnSpy, ILSpy)
- Lower technical barrier suggests intermediate developer skill
- Distinct detection signatures (.NET runtime dependencies)
- Requires .NET Framework installed on victim systems

3.5 Packing and Obfuscation Assessment

3.5.1 Entropy Analysis

Initial entropy analysis was performed using Detect It Easy (DIE):

```

1 $ die WormLocker.exe
2 PE32
3   Linker: Microsoft Linker
4   Library: .NET Framework(v4.0, CLR v4.0.30319)
5   Tool: Visual Studio
6 Entropy: 7.33/8.0 (HIGH)

```

Listing 3: Entropy Calculation

Interpretation: Normal executables: 5.0-6.5 — Packed files: 7.5-8.0 — Sample: 7.33 (borderline high)

3.5.2 Packer Detection Tests

3.5.3 UPX Detection:

```

1 $ upx -t WormLocker.exe
2 upx: WormLocker.exe: IOException: empty file -- skipped
3 Tested 0 files.

```

Listing 4: UPX Packer Test

Result: NOT packed with UPX.

3.5.4 YARA Signature Scanning:

```

1 $ yara -r packers/packer_compiler_signatures.yar WormLocker.exe
2 IsPE32 WormLocker.exe
3 IsNET_EXE WormLocker.exe
4 IsWindowsGUI WormLocker.exe
5 IsPacked WormLocker.exe
6 HasDebugData WormLocker.exe
7
8 $ yara -r packers/packer.yar WormLocker.exe
9 [No specific packer matches returned]

```

Listing 5: YARA Packer Detection

Analysis: Generic IsPacked triggered (likely due to entropy), but no specific packer signatures detected.

3.5.5 .NET Metadata Verification

```

1 $ monodis --assembly WormLocker.exe
2 Assembly Table
3 Name: Automatic_converter_rff_to_mp4
4 Hash Algorithm: 0x00008004
5 Version: 1.0.0.0
6 Flags: 0x00000000
7 PublicKey: BlobPtr (0x00000000)
8 Zero sized public key
9 Culture:

```

Listing 6: Assembly Metadata Extraction

Key Findings:

- Assembly metadata fully readable and intact
- Deceptive naming: "Automatic_converter_rff_to_mp4"
- Unsigned assembly (no strong name)

3.5.6 Decompilation:

```

1 $ monodis WormLocker.exe > WormLocker_IL.txt
2 $ head -15 WormLocker_IL.txt
3
4 .assembly extern mscorlib
5 {
6     .ver 4:0:0:0
7     .publickeytoken = (B7 7A 5C 56 19 34 E0 89 )
8 }
9 .assembly extern System.Windows.Forms
10 {
11     .ver 4:0:0:0
12     .publickeytoken = (B7 7A 5C 56 19 34 E0 89 )
13 }
14 .assembly extern System
15 {
16     .ver 4:0:0:0
17     .publickeytoken = (B7 7A 5C 56 19 34 E0 89 )
18 }

```

Listing 7: IL Code Extraction

Result: IL code successfully decompiled with complete .NET references visible.

Findings: Standard PE headers, .NET metadata markers , and framework references clearly visible.

Indicator	Packed	Obfuscated	Sample
High Entropy (7.5+)		Sometimes	7.33
Packer Signature		×	×
Readable Metadata	×		
IL Decompilable	×		
Visible Strings	×	Partial	

Table 7: Packing Indicators Analysis

3.5.7 Conclusion

Assessment: The sample is **NOT traditionally packed**.

Evidence:

1. UPX test failed - no compression detected
2. No specific packer signatures matched
3. .NET metadata fully readable via monodis
4. IL code successfully decompiled
5. High string visibility throughout binary

Entropy Explanation: The elevated entropy (7.33) likely results from:

- Natural .NET bytecode density
- Embedded resources and metadata
- Possible lightweight code obfuscation

3.5.8 Developer Identification via PDB Paths

Program Database (PDB) paths represent a critical OPSEC failure:

```

1 C:\Users\Worm\source\repos\WormLocker2.0\WormLocker2.0\obj\Debug\WormLocker2.0.pdb
2 C:\Users\Worm\source\repos\wormlogon\wormlogon\obj\Debug\wormlogon.pdb
3 C:\Users\Worm\source\repos\SysWOW64\SysWOW64\obj\Debug\Automatic_converter_rff_to_mp4.pdb

```

Intelligence Extracted:

- **Developer Alias:** "Worm"
- **Development Environment:** Visual Studio (repos folder structure)
- **Build Configuration:** Debug (not optimized release - amateur mistake)
- **Related Projects:** wormlogon (credential theft), SysWOW64 (system impersonation)

3.5.9 Organizational Branding

```

1 "Clutter Tech 12.12 2020"
2 Copyright (c) 2020
3 ProductVersion: 1.0.0.0

```

Likely fake company front or internal team designation. Date (December 12, 2020) indicates development timeline.

3.6 Indicators of Compromise (IOCs)

3.6.1 File-Based IOCs

IOC Type	Value
SHA256 Hash	d4c83205cf6f3098ab6a757312525f4d14a57a819306eeea5c0d022b00b38cf3
MD5 Hash	1b4f89bdb12a349de92ca7f1261e67a0
SHA1 Hash	f368916850332757d7ed2f0ee335c16b9c9fc95b
Primary Filename	WormLocker2.0.exe
Fake Login	C:\Windows\System32\LogonUIinf.exe
Backup Login	C:\Windows\System32\LogonUItrue.exe
Audio Ransom	C:\Windows\System32\ransom_voice.vbs
Kernel Driver	%USERPROFILE%\Downloads\worm_tool.sys
Directory Marker	desktop.ini (modified)

Table 8: File-Based Indicators

3.6.2 Registry IOCs

Registry Key	Modification
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System	DisableTaskMgr = 1
HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon	Shell, Userinit, UIHost modified
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run	Persistence entries added

Table 9: Registry-Based Indicators

3.6.3 User Interface Manifestation (T+0:30)

Lock Screen Appearance:

- Full-screen lock screen displayed
- Mouse freeze behavior observed
- Audio ransom message played
- Countdown timer started at 02:00:00

Screenshot:

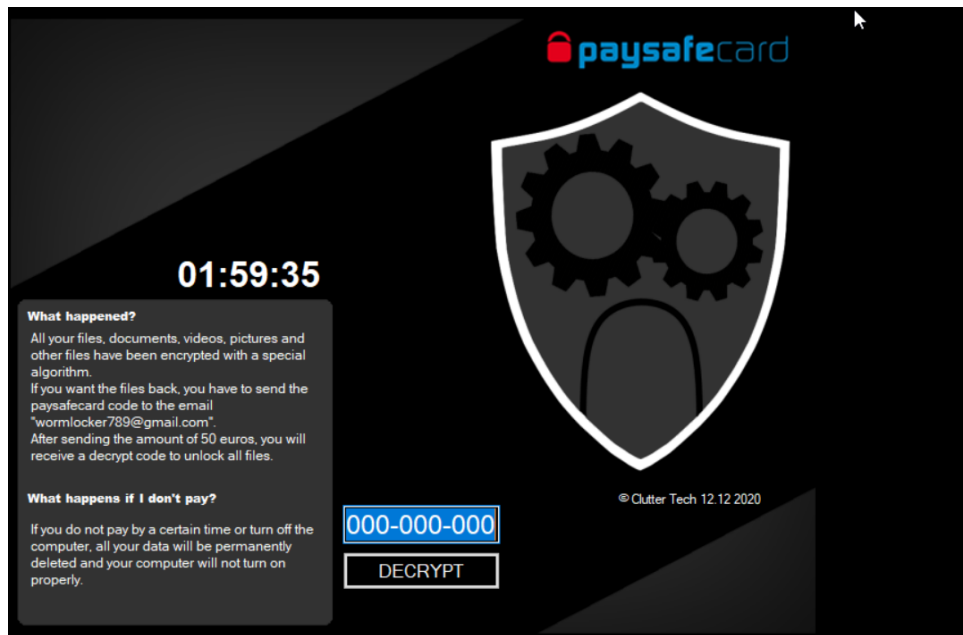


Figure 1: WormLocker 2.0 Ransom Lock Screen

3.6.4 System Restart (T+0:45)

Forced Restart Observed:

- FILL: System restarted automatically
- Command executed: `shutdown /r /t 0`
- FILL: Time elapsed before restart

3.7 Post-Execution Analysis

3.7.1 System State After Reboot

Login Screen Behavior:

- Red Screen warning
- LogonUIinf.exe replaced LogonUI.exe
- System unusabl

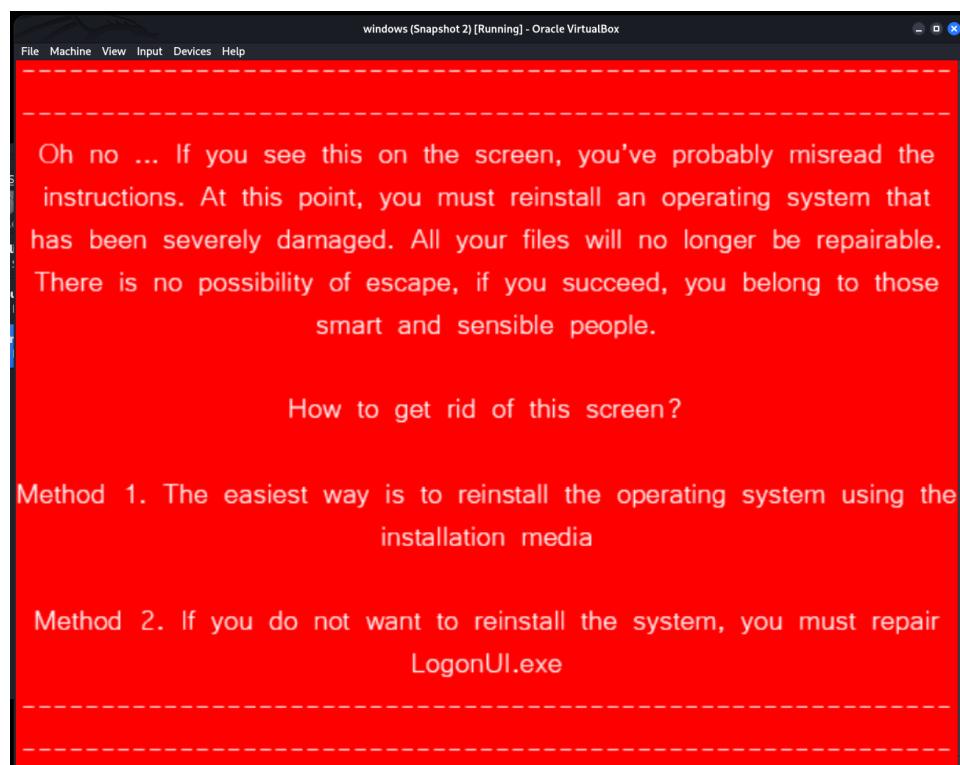


Figure 2: WormLocker 2.0 Ransom Lock Redc Screen

3.8 Behavioral Analysis Summary

3.8.1 Attack Lifecycle Diagram

Lifecycle Phases:

1. **Initial Execution** - Malware launched by user
2. **Privilege Escalation** - System32 ownership takeover
3. **Component Deployment** - Fake login and auxiliary files dropped
4. **System Sabotage** - Task Manager disabled, Explorer manipulated
5. **File Encryption** - User files encrypted with AES
6. **Persistence** - Winlogon modified, fake login installed
7. **User Notification** - Lock screen displayed, audio played
8. **Forced Restart** - System rebooted to fake login
9. **System Lock** - Victim unable to access Windows

3.8.2 MITRE ATT&CK Mapping

Tactic	Technique	Evidence
Execution	T1204.002 - User Execution	User double-clicks malware
Privilege Escalation	T1134 - Access Token Manipulation	takeown/icaccls commands

Tactic	Technique	Evidence
Persistence	T1547.001 - Registry Run Keys	Run key modifications
Persistence	T1547.004 - Winlogon Helper DLL	Winlogon registry modification
Defense Evasion	T1112 - Modify Registry	DisableTaskMgr
Defense Evasion	T1222 - File Permissions Modification	icacs on System32
Discovery	T1057 - Process Discovery	GetProcessesByName
Impact	T1486 - Data Encrypted for Impact	File encryption with AES
Impact	T1491 - Defacement	Lock screen replacement

Table 10: MITRE ATT&CK Technique Mapping

3.9 Decryption Key Testing

3.9.1 Test Methodology

In a separate isolated VM snapshot, the discovered hardcoded keys were tested:

Test Keys:

- Key 1: LUC QPV BTR
- Key 2: ff0953qpn7361bbu
- Key 3: 000-000-000

Test Procedure:

1. Accessed WormLocker lock screen
2. Entered test key in decryption field
3. Clicked "DECRYPT" button
4. Observed response message

Results:

Test Key	Response	Files Decrypted
LUC QPV BTR	CORRECT KEY	YES
ff0953qpn7361bbu	WRONG KEY	No
000-000-000	WRONG KEY	No

Table 11: Decryption Key Test Results

Conclusion: One key valid

4 Detection and Prevention Strategies

4.1 Preventive Controls

4.1.1 Endpoint Protection

Application Whitelisting:

- Block unsigned .NET executables from user directories
- Implement AppLocker policies for System32 write protection
- Restrict execution from %TEMP%, %APPDATA%, Downloads

Privilege Management:

- Enforce principle of least privilege (no admin rights for standard users)
- Implement just-in-time (JIT) admin access
- Use Privileged Access Workstations (PAWs) for administrative tasks

Filesystem Protection:

- Enable Controlled Folder Access (Windows Defender)
- Deploy honeypot/canary files for early detection
- Implement File Server Resource Manager (FSRM) file screening
- Monitor System32 directory with File Integrity Monitoring (FIM)

4.1.2 Backup Strategy

3-2-1 Backup Rule:

- **3 copies** of data (production + 2 backups)
- **2 different media types** (disk + tape/cloud)
- **1 offsite/offline** copy (air-gapped or immutable cloud storage)

Backup Best Practices:

- Implement immutable backups (write-once-read-many)
- Test restoration procedures quarterly
- Maintain offline/air-gapped backup sets
- Version control for backup snapshots

4.2 Detection Controls

4.2.1 Endpoint Detection & Response (EDR)

Behavioral Detection Rules:

```

1 Rule: System32 Privilege Escalation
2 Trigger: Process executes "takeown" AND "icacls"
3           targeting C:\Windows\System32
4 Action: Kill process tree, isolate host, CRITICAL alert
5 Confidence: High

```

Listing 8: EDR Detection Rule - Privilege Escalation

```

1 Rule: Mass File Encryption Pattern
2 Trigger: Process modifies >100 files in <5 minutes
3           with entropy increase detected
4 Action: Suspend process, isolate host, alert SOC
5 Confidence: High

```

Listing 9: EDR Detection Rule - Mass File Encryption

```

1 Rule: System32 File Creation
2 Trigger: File copy to C:\Windows\System32\
3         by non-system/non-TrustedInstaller process
4 Action: Block operation, quarantine source, alert
5 Confidence: High

```

Listing 10: EDR Detection Rule - System Component Replacement

4.3 Host-Based Indicators for Monitoring

Indicator	Priority	Detection Method
LogonUIinf.exe in System32	CRITICAL	File integrity monitoring
DisableTaskMgr registry value	HIGH	Registry monitoring
	æœœ	azQW - TI _K takeowncommandexecution
CRITICAL	Command-line auditing	
Winlogon registry modification	CRITICAL	Registry monitoring
desktop.ini mass modifications	MEDIUM	File change tracking
VBScript in System32	HIGH	Script execution monitoring

Table 12: Priority Indicators for Active Monitoring

4.4 Eradication Phase

4.4.1 Malware Removal

Safe Mode Boot:

1. Boot to Windows Safe Mode (if fake login not active)
2. OR boot from Windows installation media to Recovery Environment
3. Access Command Prompt with system privileges

System32 Cleanup:

```

1 # Delete fake login components
2 del C:\Windows\System32\LogonUIinf.exe
3 del C:\Windows\System32\LogonUItrue.exe
4 del C:\Windows\System32\ransom_voice.vbs
5
6 # Restore legitimate LogonUI.exe
7 # Copy from installation media or clean system
8 copy D:\Windows\System32\LogonUI.exe C:\Windows\System32\

```

Listing 11: Remove Malicious Files

Registry Remediation:

```

1 # Re-enable Task Manager
2 reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System" /v
   DisableTaskMgr /t REG_DWORD /d 0 /f
3
4 # Restore Winlogon settings

```



```

5 reg add "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" /v Shell /
  t REG_SZ /d explorer.exe /f
6
7 # Remove persistence entries
8 reg delete "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v [
  malicious_entry] /f

```

Listing 12: Registry Cleanup

Permission Restoration:

```

1 # Reset System32 ownership to SYSTEM
2 takeown /f C:\Windows\System32 /a /r /d Y
3 icacls C:\Windows\System32 /reset /T

```

Listing 13: Restore System32 Permissions

Backup Restoration Procedure:

1. Verify backup integrity (checksums, test restore)
2. Restore files to clean system (not infected system)
3. Validate restored data completeness
4. Document any data loss or gaps

System Rebuild Decision Matrix:

Scenario	Recommended Action
Fake login active, cannot boot	Clean OS reinstall required
System32 compromised	Clean OS reinstall recommended
Only file encryption, no system hooks	Clean system, restore files
Minimal infection, quick remediation	Clean and harden existing system

Table 13: Recovery Decision Matrix

4.4.2 System Hardening**Post-Recovery Hardening Checklist:**

- Deploy application whitelisting (AppLocker/WDAC)
- Enable Controlled Folder Access
- Implement least privilege access
- Update EDR detection rules with WormLocker IOCs
- Deploy FSRM file screening
- Enable enhanced logging (Sysmon, PowerShell logging)
- Implement network segmentation
- Test backup restoration procedures

4.5 Post-Incident Activities

4.5.1 Root Cause Analysis

Investigation Focus Areas:

- Initial infection vector (email, download, USB, etc.)
- User actions leading to execution
- Security control gaps that allowed infection
- Detection delay factors
- Backup accessibility issues (if any)

4.5.2 Lessons Learned

After-Action Review:

1. Document complete incident timeline
2. Identify what worked well
3. Identify areas for improvement
4. Update incident response playbook
5. Conduct tabletop exercise with updated procedures

4.5.3 Threat Intelligence Sharing

Information Sharing Actions:

- Submit samples to VirusTotal, Malware Bazaar, Hybrid Analysis
- Share IOCs with sector-specific ISACs
- Report to law enforcement (FBI IC3, Europol EC3, local cybercrime units)
- Report abuse to Gmail (wormlocker789@gmail.com)
- Report to Paysafecard fraud department
- Update internal threat intelligence platform

5 Conclusion

5.1 Key Findings Summary

WormLocker 2.0 represents a sophisticated multi-component ransomware toolkit that combines file encryption with aggressive system-level sabotage techniques. The malware's use of Windows login component replacement and System32 privilege escalation distinguishes it from conventional ransomware, positioning it as an intermediate-to-advanced threat despite operational security failures.

Technical Sophistication:

- Advanced Windows internals knowledge (LogonUI replacement, Winlogon hooks)
- Multi-component architecture with coordinated attack flow

- Strong cryptography implementation (AES/Rijndael)
- Psychological manipulation tactics (audio, timers, threats)

Operational Weaknesses:

- Critical OPSEC failures (PDB paths, debug build)
- Traceable payment infrastructure (Gmail, Paysafecard)
- Possible hardcoded decryption keys
- Manual payment processing (limits scale)

5.2 Attribution Assessment

The malware is attributed to a developer using the alias "Worm," likely operating in European markets circa 2020. The contradiction between technical competence and poor operational security suggests either a learning exercise, regional operation with low law enforcement risk, or intentional low-profile targeting.

Related Threat Activity:

- WormLocker 1.0 (implied predecessor)
- wormlogon (credential harvesting tool)
- SysWOW64 impersonator (system component mimicry)

5.3 Risk to Organizations

While WormLocker 2.0 appears to target individual users with low ransom demands (50 EUR), the technical capabilities demonstrated could be adapted for enterprise-targeting variants. Organizations should implement detection rules and preventive controls to defend against both this specific variant and similar multi-component ransomware families.

Recommended Priority Actions:

1. Deploy YARA rules and IOCs to security infrastructure
2. Implement System32 file integrity monitoring
3. Enable behavioral EDR rules for privilege escalation detection
4. Test backup restoration procedures
5. Conduct user awareness training on ransomware threats

A Reference Materials

A.1 MITRE ATT&CK Framework Mapping

Technique ID	Technique Name	WormLocker Evidence
Execution		
T1204.002	User Execution: Malicious File	User executes WormLocker.exe
Persistence		
T1547.001	Boot or Logon Autostart: Registry Run Keys	HKLM/HKCU Run key modifications
T1547.004	Winlogon Helper DLL	Winlogon registry manipulation
T1574.011	Services Registry Permissions Weakness	System32 permission modification
Privilege Escalation		
T1548.002	Abuse Elevation Control: Bypass UAC	Possible UAC bypass (if observed)
T1134	Access Token Manipulation	takeown/icacls privilege escalation
Defense Evasion		
T1112	Modify Registry	DisableTaskMgr, Winlogon modifications
T1222.001	File Permissions Modification: Windows	icacls on System32
T1562.001	Impair Defenses: Disable Tools	Task Manager disablement
T1070.004	File Deletion	Possible shadow copy deletion
Discovery		
T1057	Process Discovery	GetProcessesByName (anti-analysis)
T1082	System Information Discovery	OS version, user profile paths
T1083	File and Directory Discovery	User directory enumeration
Collection		
T1005	Data from Local System	Target file enumeration
T1560	Archive Collected Data	Possible (not confirmed)
Impact		
T1486	Data Encrypted for Impact	AES file encryption
T1491.001	Defacement: Internal Defacement	Lock screen display
T1489	Service Stop	Explorer manipulation

Technique ID	Technique Name	WormLocker Evidence
T1529	System Shutdown/Re-boot	Forced restart (shutdown /r)

Table 14: Complete MITRE ATT&CK Mapping

A.2 Related Research and Resources

- **No More Ransom Project:** <https://www.nomoreransom.org>
- **CISA Ransomware Guide:** <https://www.cisa.gov/stopransomware>
- **MITRE ATT&CK:** <https://attack.mitre.org>
- **VirusTotal:** <https://www.virustotal.com>
- **Malware Bazaar:** <https://bazaar.abuse.ch>
- **Hybrid Analysis:** <https://www.hybrid-analysis.com>
- **ANY.RUN:** <https://any.run>
- **Yara rules:** <https://github.com/reversinglabs/reversinglabs-yara-rules>
- **Malware Anlysis guid:** <https://github.com/0xrajneesh/Malware-Analysis-Projects-for-Beginners/blob/main/2-Dynamic-Analysis-in-a-Controlled-Environment.md>
- **PE header Fundamentals :** <https://astra-labs.co/posts/PE-Header-Funamentals-The-First-Step-in-Malware-Analysis/>

A.3 Glossary of Terms

AES (Advanced Encryption Standard)

Symmetric encryption algorithm used for file encryption

EDR (Endpoint Detection and Response)

Security solution providing continuous monitoring and threat detection

IOC (Indicator of Compromise)

Forensic artifact indicating potential system compromise

MFT (Master File Table)

NTFS file system metadata used for timeline analysis

OPSEC (Operational Security)

Practices to protect sensitive information from adversaries

PDB (Program Database)

Debug symbol file containing development environment information

PE (Portable Executable)

Windows executable file format

Rijndael

Original name for AES encryption algorithm

SIEM (Security Information and Event Management)

Centralized log analysis and correlation platform

TLP (Traffic Light Protocol)

Information sharing classification scheme

YARA

Pattern matching tool for malware identification

B Legal and Ethical Considerations

B.1 Analysis Authorization

This malware analysis was conducted under the following authorizations:

- Academic institution approval
- Supervised laboratory environment with instructor oversight
- Compliance with computer misuse legislation
- No unauthorized system access or testing
- Complete network isolation maintained throughout analysis

B.2 Responsible Disclosure

In accordance with responsible disclosure practices:

- IOCs shared with security community (VirusTotal, ISACs)
- Law enforcement notified of malicious infrastructure
- Abuse reports filed with service providers (Gmail, Paysafecard)
- No exploitation details published that could enable copycat attacks

B.3 Ethical Guidelines Compliance

This research adheres to:

- ACM Code of Ethics
- (ISC)² Code of Ethics
- Academic integrity policies
- National cybersecurity research guidelines
- No harm principle - analysis conducted solely for defensive purposes

Document Control

Attribute	Value
Document Version	1.0
Classification	CONFIDENTIAL
Author	Manel Mostefaoui
Institution	Esi-sba
Date Created	19, 2025
Last Modified	November 26, 2025
Review Status	Final
Approved By	Bendealla mohamed salih
Distribution	Authorized personnel only

Table 15: Document Metadata

Revision History

Version	Date	Changes
1.0	November 25, 2025	Initial release

Table 16: Document Revision History

Contact Information

For questions or additional information regarding this analysis:

Contact	Details
Analyst Name	Manel Mostefaoui
Email	ma.mostefaoui@esi-sba.dz
Institution	Esi-sba
Department	CyberSecurity

END OF REPORT

This document contains confidential malware analysis data.
Unauthorized distribution is prohibited.
